

Annual Information Security Audit

Northwind Outdoor Co. — Confidential

Auditor: Bluefield Security Partners. Lead auditor: Jordan Park, CISSP. Audit period: 1 August 2025 – 15 September 2025.

Report issued: 28 September 2025.

Executive Summary

Bluefield Security Partners reviewed Northwind Outdoor Co.'s security posture against the SOC 2 Type II control framework. The audit identified **24 findings: 3 critical**, 7 high, 10 medium, and 4 low. The highest-risk system is the ERP Production server (asset NW-SRV-0007), which is running an end-of-life OS and is the subject of two of the three critical findings. Management has committed to remediation milestones detailed in Section 4.

Methodology

The audit included automated vulnerability scans (Tenable Nessus), configuration reviews of the production AWS account, social-engineering phishing tests against 412 employees (8.5% click rate), and credentialed reviews of access controls in the ERP, the Shopify storefront, and the EDI gateway used for wholesale orders.

ID	Severity	Affected system	Description	Status
F-001	Critical	ERP Production	EOL OS — Windows Server 2012 R2 still in production.	Open
F-002	Critical	ERP Production	Local admin password reused across 4 servers.	Open
F-003	Critical	EDI Gateway	SFTP listener accepts weak HMAC-SHA1 in violation of policy.	In progress
F-004	High	AWS — prod	S3 bucket nw-prod-logs allows public list.	In progress
F-005	High	AWS — prod	Root account does not have hardware MFA enabled.	Open
F-006	High	Shopify storefront	No alerting on excessive failed-login attempts.	Open
F-007	High	Office network	Guest Wi-Fi shares VLAN with point-of-sale at Denver hub.	Open
F-008	High	Slack	Legacy bot tokens with broad scopes remain installed.	Closed
F-009	High	Backups	Off-site backup verification has not been tested in 11 months.	Open
F-010	High	Customer DB	Field-level encryption not applied to PII outside primary key.	In progress

F-011	Medium	Endpoint	EDR coverage at 87% — gap is mostly contractor laptops.	In progress
F-012	Medium	ERP Production	Audit logging retention is 30 days; policy requires 365.	Open
F-013	Medium	AWS — prod	IAM users with console access do not require MFA.	In progress
F-014	Medium	Code repos	Branch protection not enforced on the 'release/*' pattern.	Closed
F-015	Medium	CI / CD	Long-lived deploy token in GitHub Actions for the storefront.	Open
F-016	Medium	DNS	DMARC policy is set to p=none.	Open
F-017	Medium	Vendor mgmt	Three subprocessors lack signed DPAs.	In progress
F-018	Medium	HR offboarding	Avg time from termination to access revocation: 4.2 days.	Open
F-019	Medium	Backups	Backups for the Shopify export are stored unencrypted at rest.	In progress

F-020	Medium	Logging	No SIEM correlation rule for impossible-travel auth events.	Open
F-021	Low	Workstations	Screen-lock timeout policy not enforced on macOS.	Open
F-022	Low	Printers	Default admin credentials unchanged on 2 printers.	Closed
F-023	Low	Wi-Fi	Guest SSID password rotated annually, policy requires monthly.	Open
F-024	Low	Documentation	Incident response runbook last reviewed 14 months ago.	Open

Remediation Commitments

Management has committed the following milestones: F-001 retire Windows Server 2012 R2 by 31 December 2025; F-002 implement per-host local admin password rotation by 30 November 2025; F-003 disable SHA-1 HMAC on the EDI gateway by 15 October 2025.